NOVAPAY FINANCIAL SERVICES

Closing the Governance Gap

Audit findings, ISMS documents and a 90-day roadmap for a fast-growing digital payments business

10 risks assessed

20 Annex A controls

2 new policies

90 days to partner-ready

Cybersecurity programme capstone (GRC) | Prepared for the Head of Operations and Executive Management | Auditor: Oluwatosin A. Fagbayimu | v1.0, 22 Oct 2026

CONTENTS

What this submission contains

Part	Content	Type	Document no.	Slide
1	Business-facing assessment: summary, audit terms, findings, frameworks	**Audit summary**	–	3
2	Deliverable 1: Scope statement	**Updated**	NP-ISMS-DOC-001	12
3	Deliverable 2: Leadership commitment statement	**Updated**	NP-ISMS-DOC-002	14
4	Deliverable 3: Risk assessment and treatment procedure	**Updated**	NP-PRO-RAT-001	17
5	Risk register, treatment plan and roadmap	**Supporting**	–	20
6	Deliverable 4: Information Security Policy	**New policy**	NP-POL-ISP-001	24
7	Deliverable 5: Incident Response Policy	**New policy**	NP-POL-IRP-001	26
8	Deliverable 6: Statement of Applicability, 20 Annex A controls	**Updated**	NP-ISMS-DOC-003	29
9	Audit conclusion, evidence plan, glossary and references	**Conclusion**	–	32

NovaPay has outgrown its governance, and its partners have noticed

Bottom line NovaPay keeps its key partnerships only if, within about 90 days, it can show that third-party access to customer financial data is controlled, a named person is accountable for compliance in every country, and risks are managed with one method and one register. Today it can show none of the three.

10
risks assessed

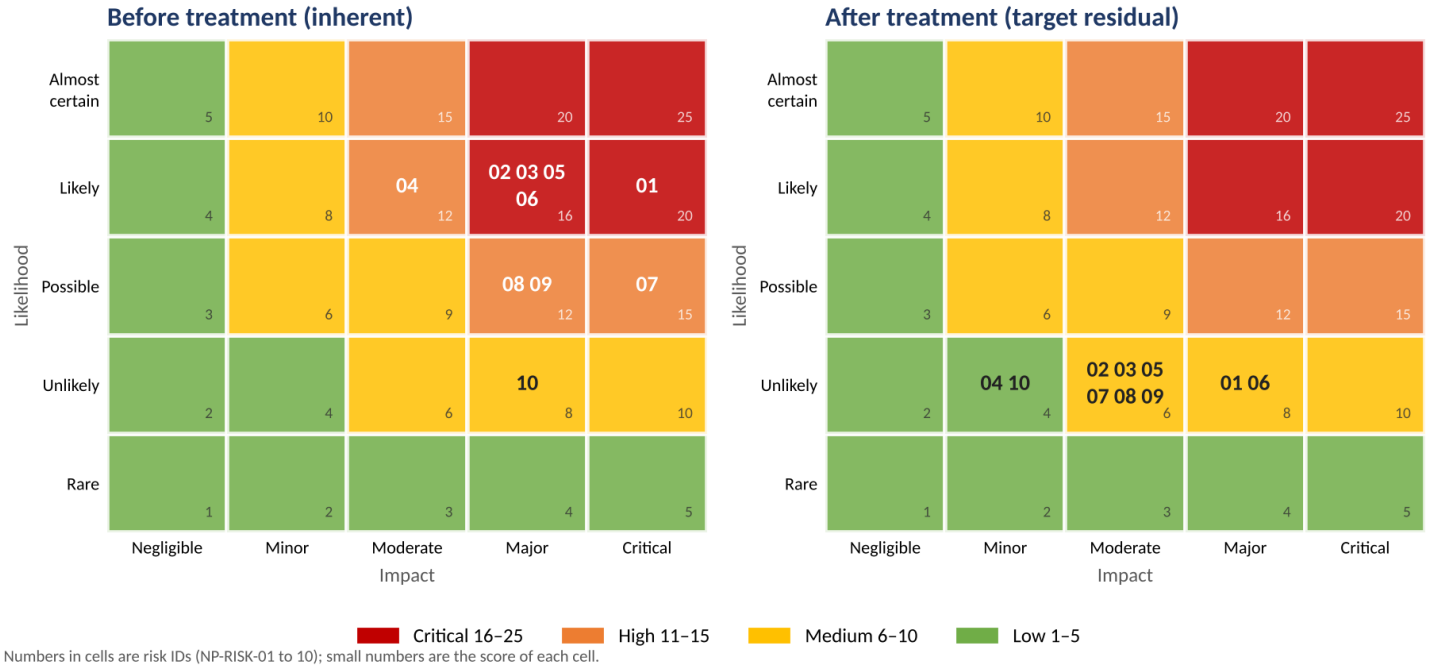
5
Critical before treatment

0
Critical or High after the roadmap

20 / 25
top risk: ungoverned third-party API access

- The five Critical risks share one root cause: no common standard that applies in every region.
- The gap that most threatens revenue is evidence: records a partner or regulator can inspect.
- Founded 2018; 3 million+ app users; 500+ merchant integrations; CBN and NDPC supervised.

Five Critical risks today; none Critical or High after the roadmap



Numbers in cells are risk IDs (NP-RISK-01 to 10); small numbers are the score of each cell.

- Inherent scores (before treatment) are shown against targets after treatment.
- Eight risks end Medium and two Low.
- Risk 06 stays at 8: financial impact remains possible even with good detection, so the CEO should accept it knowingly.
- Residual scores are targets until evidence shows controls operate.

Residual scores assume the Part 5 roadmap is delivered.

Five priority actions close the largest exposures

#	Priority action	Why it matters	Lead	By
1	List every third-party API integration; give each an owner, approved data scope and review date; revoke credentials nobody owns	Closes the largest exposure (risk 01)	CTO	31 Jan 2027
2	Name a compliance owner for each country and publish an obligations register	Ends uncertainty over who answers to regulators	Head of Risk & Compliance	31 Dec 2026
3	Adopt one risk method and register; run workshops in every region	Lets leadership compare risks and justify spend	CISO	31 Jan 2027
4	Make one onboarding and due-diligence process mandatory for partners, agents and vendors	Stops unsuitable parties getting access	Head of Operations	28 Feb 2027
5	Compile an evidence pack and test the first controls	Turns policy into proof for renewals	Head of Risk & Compliance	Day 90

Four decisions are needed from leadership in the first 45 days

Day 15

Approve the Information Security Policy and Incident Response Policy

Who: CEO

Day 30

Appoint the RMC team and a Regional Compliance Lead per country

Who: CEO, CISO

Day 30

Rule that no new integration goes live without an owner, contract terms and an approved access scope

Who: CEO, Head of Operations, CTO

Day 45

Confirm risk appetite and impact thresholds; approve capacity for the roadmap

Who: CEO, Finance

Audit terms of reference: what was audited, against what, and how

Element	Terms
Engagement	GRC audit and ISMS readiness assessment, completed as a capstone project for the cybersecurity programme
Objective	Judge how ready NovaPay's governance, risk and third-party controls are for ISO/IEC 27001:2022, and design the missing ISMS documents
Scope	Governance, payments, merchant API platform, customer data, regional operations and supplier relationships (Part 2)
Criteria	ISO/IEC 27001:2022 clauses 4–10 and Annex A; ISO 27002:2022; ISO 31000; NIST CSF 2.0; PCI DSS v4.0.1; NDPA 2023; CBN rules
Method	Document review of the case, gap analysis, 5 × 5 risk assessment, control selection and crosswalk, roadmap design
Evidence and rating	Each finding is labelled Stated, Inferred or Assumed and rated Critical, High, Medium or Low
Limits	No interviews, system evidence or technical tests; this is a readiness view, not a certification audit opinion

Findings F1–F4: access, ownership, consistency, onboarding

ID	Finding (evidence basis)	Business effect	Recommended response	Owner, by	Rating
F1	Third-party API access to customer financial data has no governing process (Stated)	Data could be exposed or altered; no proof of who has access	Inventory integrations; enforce scopes; revoke orphaned credentials; review API logs	CTO, 31 Jan 2027	Critical
F2	Nobody clearly owns compliance obligations in each country (Stated)	Duties missed; contradictory answers to regulators	Regional compliance leads; obligations register; one exception process	Head of R&C, 31 Dec 2026	Critical
F3	Policies are applied differently by country (Stated)	The weakest office sets the real standard	One policy baseline; local variation only for local law	CISO, 31 Jan 2027	High
F4	Partners, agents and vendors are onboarded without a common standard (Stated)	A weak party may get production access unchecked	Risk tiers; evidence review and contract terms before access	Head of Ops, 28 Feb 2027	Critical

Findings F5–F8: data, detection, incidents, evidence

ID	Finding (evidence basis)	Business effect	Recommended response	Owner, by	Rating
F5	Customer data, incl. cross-border transfers, is handled inconsistently (Stated)	Privacy and regulatory exposure	Data-flow records; transfer basis; retention; encryption	DPO, 31 Mar 2027	Critical
F6	Fraud and API-abuse detection may differ by country and channel (Inferred)	Losses and findings from unseen activity	Central logging; detection use-cases; named alert owners	CISO, 31 Mar 2027	Critical
F7	Incident escalation and notification are probably not standard (Assumed)	Slow response; missed reporting duties	Incident plan with severity levels and notification steps; tabletop	CISO, 28 Feb 2027	High
F8	No assurance evidence exists for partners or regulators (Stated)	Renewals and integrations delayed or lost	Evidence pack; honest gap list with dated plans	Head of R&C, day 90	Critical

ISO 27001 is the backbone; other frameworks have narrower jobs

Framework or law	Role at NovaPay	Decision and action
ISO/IEC 27001:2022	Management system: scope, leadership, risk, audit, improvement	Adopt. Certification optional, later
ISO 31000:2018	Principles behind the risk method	Adopt as guidance (Part 4)
NIST CSF 2.0	Common language for reporting outcomes to leadership	Adopt for reporting; use the crosswalk
PCI DSS v4.0.1	Applies if NovaPay or partners store, process or transmit cardholder data	Likely: confirm scope; treat v4.0 future-dated requirements (since 31 Mar 2025) as in force
NDPA 2023 and NDPC GAID 2025	Privacy duties for customer data	Applies: Legal to confirm registration, DPO and audit duties
EU GDPR	Only where Article 3 territorial triggers are met	Conditional: Legal to confirm
CBN rules and other national laws	Licence-specific payment and banking rules; local laws per country	Applies: map obligations to licences in the register

Crosswalk: one ISO control also serves NIST CSF and PCI DSS

Annex A control	NIST CSF	PCI	Risk
A.5.1 Policies for information security	GV.PO	12.1	04
A.5.2 Roles and responsibilities	GV.RR	12.1	03
A.5.15 Access control	PR.AA	7	01
A.5.19 Supplier relationships	GV.SC	12.8	02
A.5.24 Incident mgmt planning	RS.MA	12.10	07
A.5.31 Legal and regulatory	GV.OC	12.4	03
A.5.34 Privacy and PII	PR.DS	3	05
A.6.1 Screening	GV.RR	12.7	09
A.6.3 Awareness and training	PR.AT	12.6	04
A.6.7 Remote working	PR.IR	8	09

Annex A control	NIST CSF	PCI	Risk
A.7.1 Physical perimeters	PR.AA	9	10
A.7.2 Physical entry	PR.AA	9	10
A.7.14 Secure disposal of equipment	PR.DS	9	10
A.8.3 Information access restriction	PR.AA	7	01
A.8.5 Secure authentication	PR.AA	8	01
A.8.15 Logging	DE.CM	10	06
A.8.16 Monitoring activities	DE.CM, DE.AE	10	06
A.8.20 Networks security	PR.IR	1	08
A.8.24 Use of cryptography	PR.DS	3, 4	05, 08
A.8.26 Application security req.	PR.PS	6	01

Indicative mapping; validate when the full SoA is built. GV Govern, PR Protect, DE Detect, RS Respond. PCI = DSS v4.0.1 requirement area.

UPDATED DOCUMENT

The ISMS covers payments, the API platform and every location

Scope statement The ISMS covers the delivery of NovaPay's digital payments and mobile banking services (mobile money transfers, merchant payment processing, bill payments and micro-lending), including the mobile app, the merchant API platform, the cloud infrastructure that hosts them, the supporting people and processes, and the interfaces with third-party banking agents, mobile money aggregators and banking partners, at all NovaPay locations in West and Southern Africa.

Information assets

Customer personal and financial data; transaction and merchant records; API credentials; source code; supplier records; policies and risk records

Units and locations

Executive, Operations, Technology, Risk & Compliance, InfoSec, Support, Lending, Finance, HR, Legal; Lagos HQ and all country offices; cloud environments; remote work

Interfaces

Banking partners, agents, aggregators, merchants (via API), cloud and technology providers, each with an owner, contract and Supplier Register entry

Document NP-ISMS-DOC-001 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 cl. 4.1–4.3

UPDATED DOCUMENT

Context and interested parties shape what the ISMS must do

Issue or party	What it means for the ISMS
Fast expansion; informal country processes (internal)	One ISMS and one policy set everywhere, with local legal addenda only
No unified framework; unclear compliance ownership (internal)	Standard risk procedure and register; named regional compliance owners
Cloud-native platform with API integrations (internal)	API and cloud security are central to control selection
Regulators: CBN, NDPC, national authorities (external)	Obligations register by country; evidence ready for audit
Banking partners and clients (external)	Evidence-based, audit-ready controls for renewals
3 million+ customers; 500+ merchants (external)	Safe funds and data; reliable, secure API platform

Proposed exclusions: (a) internal systems run by partners, agents, aggregators and merchants (interfaces stay in scope); (b) visitor networks, if segregation is verified.

Prepared by: GRC Analyst / Consultant	Approval: Chief Executive Officer	Approval: Chief Information Security Officer
Oluwatosin A. Fagbayimu Sign: Date: 22.10.26	Name: _____ Sign: _____ Date: _____	Name: _____ Sign: _____ Date: _____

Document NP-ISMS-DOC-001 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 cl. 4.1–4.3

UPDATED DOCUMENT

One framework, applied the same way in every region

“Information security and compliance are not back-office tasks; they are the basis of the trust that customers, merchants, banking partners and regulators place in us.”

- Set the Information Security Policy and objectives, aligned with strategy, and build the ISMS into daily operations in every country.
- Provide people, technology and funding, and name an owner for every obligation and region.
- Allow third-party access to customer financial data only under governed, documented and monitored arrangements.
- Review policy, risk results and ISMS performance at least yearly, and evidence status to regulators and partners.
- Support audits and corrective action, and promote a culture of security and improvement.

Document NP-ISMS-DOC-002 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 cl. 5.1–5.3, 6.2

UPDATED DOCUMENT

Six security objectives, each measured and owned

Objective (clause 6.2)	Measure	Target	Owner
Govern third-party API access	Integrations inventoried, contracted, access-reviewed	100 % in 6 months; quarterly review	CTO
Standardize partner and vendor onboarding	New parties onboarded via the standard process	100 % from policy go-live	Head of Operations
Clear regional ownership	Countries with named owner and obligations register	100 % in 90 days	Head of R&C
One risk process	Regions assessed on the standard method	100 % in 6 months	CISO
Audit-ready for partners	Evidence pack available on request	Within 5 working days	Head of R&C
Aware people; prompt response	Staff and agents trained; incidents triaged	≥ 95 % trained; 100 % triaged in 1 hour	CISO

Document NP-ISMS-DOC-002 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 cl. 5.1–5.3, 6.2

UPDATED DOCUMENT

Roles and responsibilities: who is accountable for what

Role	Responsibility (clause 5.3)
CEO	Accountable for ISMS effectiveness; approves policy and objectives; provides resources; signs off acceptance of Critical risks
CISO	Owns the ISMS, risk management and certification readiness; the RMC team reports to the CISO
Head of Risk & Compliance	Runs the RMC team; keeps risk, obligations and supplier registers; coordinates audits and evidence
Head of Operations; CTO	Own partner and vendor onboarding; own API, cloud and application security
Data Protection Officer	Advises on and monitors privacy compliance, including NDPC duties and cross-border transfers
Regional Compliance Leads	Own obligations and policy enforcement in their country; report to the Head of Risk & Compliance
All personnel, agents, contractors	Follow ISMS policies and report incidents promptly

Prepared by: GRC Analyst / Consultant	**Approval: Chief Executive Officer**	**Approval: Chief Information Security Officer**
Oluwatosin A. Fagbayimu Sign: Date: 22.10.26	Name: _____ Sign: _____ Date: _____	Name: _____ Sign: _____ Date: _____

Document NP-ISMS-DOC-002 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 cl. 5.3

UPDATED DOCUMENT

One repeatable method replaces informal local practice

1

Identify

Per asset or process, from inventories, threats and vulnerabilities; log in the central register as NP-RISK-nn

2

Analyse

Value assets 1–3 for confidentiality, integrity, availability; score likelihood × impact on a 5 × 5 matrix

3

Evaluate

Bands: 1–5 Low, 6–10 Medium, 11–15 High, 16–25 Critical; the rating sets the plan deadline and approver

4

Treat

Mitigate, transfer, accept or avoid; select controls from Annex A and record them in the SoA

5

Review

Quarterly register review; reassess yearly and after major changes, incidents or new regulation

Always valued 3: customer financial data, transaction data, API credentials, source code.

Document NP-PRO-RAT-001 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 cl. 6.1.2, 6.1.3, 8.2, 8.3; ISO 31000

UPDATED DOCUMENT

Scoring criteria: five levels of likelihood and impact

Level	Likelihood	Impact: operational	Impact: financial (USD)	Impact: regulatory, partner, reputation
1	Rare: not within 5 years	None visible	< 10,000	No outside awareness
2	Unlikely: once in 2–5 years	Under 1 hour; one team	10,000–50,000	Isolated complaint
3	Possible: about yearly	Payments disrupted up to 4 hours	50,000–250,000	Partner escalation; regulator query
4	Likely: several times a year, or weakness known	Up to 1 day, or several countries	250,000–1 million	Notifiable breach; partner contract at risk
5	Almost certain: monthly or happening	Extended outage; loss of funds or data	> 1 million	Sanctions or licence action; loss of partners

Dollar thresholds are initial values for the CEO to confirm against risk appetite.

UPDATED DOCUMENT

The rating decides the deadline and who must sign off

Rating	Requirement	Plan due	Residual risk accepted by
Low (1–5)	No plan needed; monitor yearly	n/a	Risk owner
Medium (6–10)	Treatment plan required	90 days	Risk owner, endorsed by CISO
High (11–15)	Plan required; act immediately	30 days	Risk owner, approved by CISO
Critical (16–25)	Plan required; start within 7 days; escalate to CISO and CEO	7 days	Risk owner and CISO, CEO sign-off

Treatment options Mitigate (apply controls), transfer (insurance or contract; accountability stays), accept (as above) or avoid (stop or restructure, for example suspend an ungoverned integration). Plans are reviewed quarterly.

Prepared by: GRC Analyst / Consultant	Approval: Chief Executive Officer	Approval: Chief Information Security Officer
Oluwatosin A. Fagbayimu Sign: Date: 22.10.26	Name: _____ Sign: _____ Date: _____	Name: _____ Sign: _____ Date: _____

Document NP-PRO-RAT-001 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 cl. 6.1.3, 8.3

Third parties and ownership dominate the Critical risks

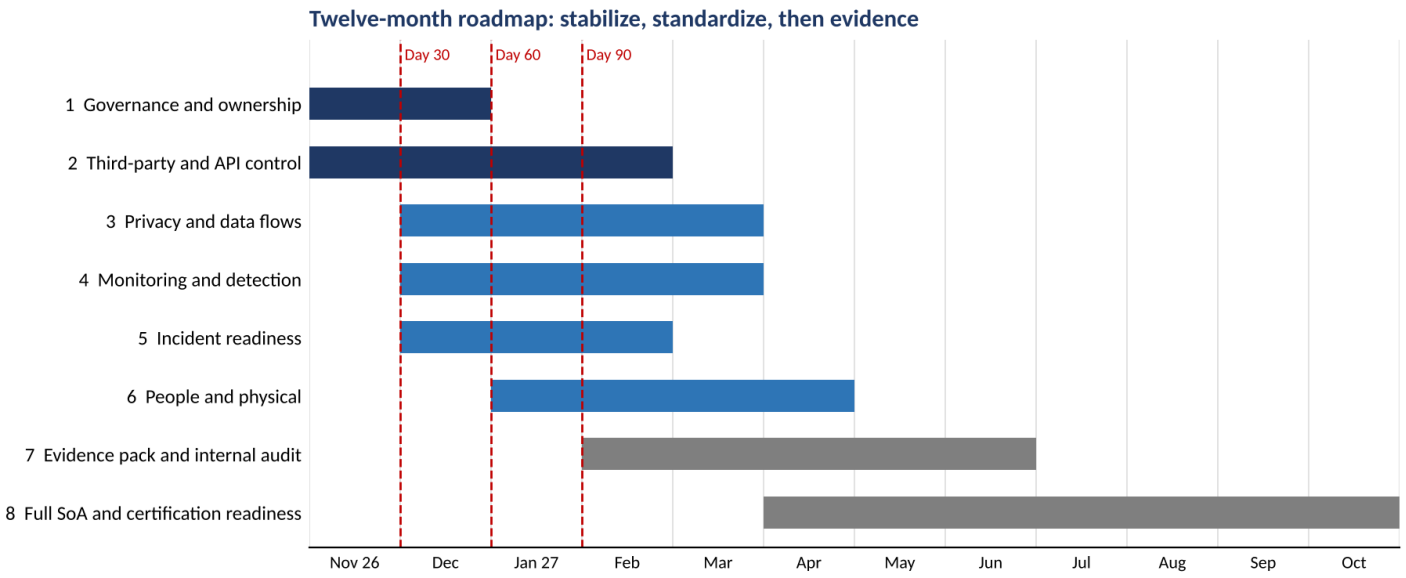
ID	Risk	Inherent	Residual	Owner	Target
NP-01	Ungoverned third-party API access to customer financial data	20 Critical	8 Medium	CTO	31 Jan 27
NP-02	Inconsistent partner, agent and vendor onboarding	16 Critical	6 Medium	Head of Ops	28 Feb 27
NP-03	Unclear compliance ownership	16 Critical	6 Medium	Head of R&C	31 Dec 26
NP-04	Inconsistent policies between regions	12 High	4 Low	CISO	31 Jan 27
NP-05	Mishandling of customer data, incl. cross-border	16 Critical	6 Medium	DPO	31 Mar 27
NP-06	Undetected fraud or API abuse across borders	16 Critical	8 Medium	CISO	31 Mar 27
NP-07	Slow or uncoordinated incident response	15 High	6 Medium	CISO	28 Feb 27
NP-08	Interception or intrusion on payment networks	12 High	6 Medium	CTO	31 Mar 27
NP-09	Insider misuse or error, incl. remote work	12 High	6 Medium	HR / CISO	30 Apr 27
NP-10	Unauthorized physical access; disposed equipment	8 Medium	4 Low	Head of Ops	30 Apr 27

Scores are initial assessments for owners to validate in workshops. IDs are NP-RISK-nn.

Every treatment action has evidence that shows it worked

Risk	Key treatment actions	Evidence that shows it worked
01	List all integrations; assign owners and scopes; revoke orphaned keys; enforce scopes at the gateway; log API calls	Integration register; revocation log; signed quarterly access review
02	Tier third parties; one due-diligence checklist; central Supplier Register; contract minimums	Completed assessments; signed agreements; register extract
03	Appoint regional leads; build the obligations register (CBN, NDPC, contracts, PCI DSS)	Appointment letters; register with owners and evidence
04	Publish the two policies; exception register; one training baseline	Approval record; training report; exception log
05	Map data flows; record transfer basis; retention rules; encryption standard	Data-flow records; transfer approvals; configuration review
06	Centralize logs; define fraud and API-abuse use-cases; name alert owners	Use-case list; alert samples with response; review minutes
07	Incident plan with severity levels and CBN, NDPC and partner notification; tabletop	Approved plan; exercise report; contact tree
08–10	Segmentation and encryption in transit; screening and remote-access standards; entry and disposal rules	Network review; screening and training records; visitor logs; disposal certificates

Eight workstreams over twelve months; evidence by day 90



Dashed lines mark days 30, 60 and 90 from approval.

Days 1–30 Stabilize
Approve policies; appoint RMC team and leads; list integrations; revoke unowned credentials

Days 31–60 Standardize
Workshops in every country; single onboarding; obligations register; incident plan

Days 61–90 Prove
Access review; tabletop; test priority controls; evidence pack v1; first KPI report

Months 4–12 Sustain
Internal audit; management review; full SoA; certification readiness decision

Five KPIs track progress; a RACI makes ownership explicit

KPI	Day 90	12 months	Owner
Integrations with owner, agreement, access review	100 % inventoried; 80 % reviewed	100 % reviewed quarterly	CTO
Countries with named owner and obligations register	100 %	100 %, reviewed quarterly	Head of R&C
New partners onboarded through the standard process	100 %	100 %	Head of Ops
Risks on the standard method; treated on time	100 % of regions	≥ 90 % on time	CISO
Staff and agents trained; incidents triaged in 1 hour	≥ 80 %; process live	≥ 95 %; 100 %	CISO

R, A, C, I	CEO	CISO	R&C	CTO	Ops	Regions
Approve policies and risk criteria	A	R	C	C	C	I
API inventory and access reviews	I	A	C	R	C	C
Partner and vendor onboarding	I	C	A	C	R	R
Risk workshops and register	I	A	R	C	C	R

NEW POLICY

Information Security Policy: purpose, scope and statement

Purpose

The top-level policy of the ISMS. It protects the confidentiality, integrity and availability of customer funds and data, transaction records, merchant integrations and supporting systems, and sets one standard for every region.

Applies to

All employees, contractors, agents and third parties who access NovaPay information or systems, at the Lagos headquarters and every country office, across the app, API platform, cloud, offices and remote work.

Policy statement: management will

- protect customer funds and data according to value and risk (NP-PRO-RAT-001);
- comply with law, regulation, contract and standards: CBN and NDPC requirements, data-protection law in each country, PCI DSS v4.0.1 where applicable, ISO/IEC 27001;
- stay consistent: one policy set in all regions, with local variation only to meet local law and approved by the CISO;
- control third parties: partner, agent, merchant and supplier access to data and APIs only under governed, recorded and monitored arrangements;
- apply least privilege and defence in depth, build security into the app and API platform, and prepare to detect, report and recover from incidents;
- improve continually through audits, management review, metrics and corrective action.

Document NP-POL-ISP-001 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 cl. 5.2, A.5.1

Information Security Policy: requirements by control area

Area	Requirement	Annex A
Governance	Named compliance owner per region; policies approved, published to all regions, reviewed on schedule	5.1, 5.2
Legal and privacy	Obligations register per country; personal data used, stored and transferred only as law permits; encrypted	5.31, 5.34, 8.24
Access	Least privilege; role-based restriction; MFA for admins and partners; quarterly access reviews	5.15, 8.3, 8.5
Third parties	Every partner, agent, aggregator, integration and supplier assessed, contracted and recorded before access	5.19
Applications and APIs	Defined security requirements: authentication, authorization, input validation, data in transit	8.26
Logging and networks	Events, API calls and transactions logged and monitored for fraud; networks segmented	8.15, 8.16, 8.20
People and premises	Screening, onboarding, annual training; secure remote working; perimeters, entry, secure wiping	6.1, 6.3, 6.7, 7.1, 7.2, 7.14
Incidents	Report at once; handled under the Incident Response Policy (Part 7)	5.24

Responsibilities, exceptions and review CEO approves and resources it; CISO owns it; Head of Risk & Compliance keeps registers and evidence; Regional Compliance Leads enforce it locally; everyone follows it and reports incidents at once. Exceptions need written CISO approval and an end date. Reviewed at least yearly.

Prepared by: GRC Analyst / Consultant	**Approval: Chief Executive Officer**	**Approval: Chief Information Security Officer**
Oluwatosin A. Fagbayimu Sign: Date: 22.10.26	Name: _____ Sign: _____ Date: _____	Name: _____ Sign: _____ Date: _____

Document NP-POL-ISP-001 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 cl. 5.2, A.5.1

NEW POLICY

Incident Response Policy: purpose, scope and severity

Purpose and scope To make every NovaPay region detect, report, contain, recover from and learn from information security incidents in one consistent, timely way, and to meet notification duties to regulators, banking partners and customers. It applies to all staff, agents, contractors and third parties, and to the app, API platform, cloud, offices and remote work. A security event is an observed occurrence; an incident is an event that harms or threatens information, systems or services.

Severity	Examples	Response target	Escalation
Critical	Confirmed or suspected breach of customer financial data; payment outage over 4 hours or across countries; active fraud or API abuse	Triage within 1 hour; response runs until contained	CEO within 1 hour; DPO and Legal at once
High	Contained intrusion; partner credential compromise; single-country outage up to 4 hours	Triage within 1 hour; contain same day	CISO at once; CEO if it worsens
Medium	Malware on an endpoint; successful phishing without data loss; policy violation	Triage within 1 hour; resolve in 1 working day	Head of Risk & Compliance
Low	Failed attack; minor event with no impact	Log within 1 hour; review in 3 working days	Incident log only

Document NP-POL-IRP-001 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 A.5.24; ISO 27002 5.24–5.28; PCI DSS 12.10

NEW POLICY

Incident Response Policy: lifecycle, roles and ownership

1 Prepare
Plan, contact tree, tools and training in place before an incident

2 Detect and report
Anyone reports at once; monitoring and log alerts raise events (A.8.15, A.8.16)

3 Triage
Incident Manager confirms, rates severity and opens the incident record

4 Contain and eradicate
Isolate systems, revoke credentials and API keys, remove the cause

5 Recover
Restore services from clean state; verify; monitor for recurrence

6 Learn
Review within 10 working days; update controls, risks and training

Role	Responsibility under this policy
Incident Manager (CISO or delegate)	Leads the response; confirms severity; owns the record, decisions and the post-incident review
Response team (Technology, Operations, RMC)	Investigate, contain, eradicate and recover; preserve evidence; keep the timeline
DPO and Legal	Assess personal-data impact and legal duties; prepare regulator, partner and customer notices
CEO and Head of Risk & Compliance	CEO informed within 1 hour of a Critical incident and approves public statements; Head of R&C keeps the register

Document NP-POL-IRP-001 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 A.5.24; ISO 27002 5.24–5.28; PCI DSS 12.10

NEW POLICY

Incident Response Policy: notification, evidence, testing

Audience	When	Owner
CEO and Executive Management	Within 1 hour for Critical incidents	Incident Manager
Data Protection Officer	Immediately if personal data may be involved	Incident Manager
NDPC	Within 72 hours of becoming aware of a breach likely to risk individuals' rights (NDPA 2023; Legal to confirm)	DPO
CBN and other national regulators	As each regulator's incident-reporting rules require, as recorded in the obligations register	Head of Risk & Compliance
Banking partners, merchants, aggregators	As each contract requires; partners must notify NovaPay within 24 hours of discovery	Head of Operations
Affected customers	Without undue delay where the risk to them is high	DPO and Legal

Evidence and records

Preserve logs and chain of custody; every incident in the register; review in 10 working days

Testing and measures

Tabletop by day 90, then yearly; contact tree tested quarterly; 100 % triaged in 1 hour

Alignment

Annex A 5.24, 8.15, 8.16, 5.34; NIST CSF RS.MA, RC; PCI DSS 12.10. Reviewed yearly

Prepared by: GRC Analyst / Consultant	Approval: Chief Executive Officer	Approval: Chief Information Security Officer
Oluwatosin A. Fagbayimu Sign: Date: 22.10.26	Name: _____ Sign: _____ Date: _____	Name: _____ Sign: _____ Date: _____

Document NP-POL-IRP-001 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 A.5.24; ISO 27002 5.24–5.28; PCI DSS 12.10

UPDATED DOCUMENT

Clause 5 organizational controls (7 of 20)

Annex A	Control name	Status	Risk	Justification
A.5.1	Policies for information security	**In progress**	04	Policy drafted (Part 6); approve and publish to all regions
A.5.2	Information security roles and responsibilities	**In progress**	03	Roles, regional leads and RMC structure defined; appointments to complete
A.5.15	Access control	**Planned**	01	Role-based least privilege and quarterly reviews, incl. third-party and API access
A.5.19	Information security in supplier relationships	**Planned**	02	Common onboarding standard and supplier register to roll out, building on Part 6 requirements
A.5.24	Incident management planning and preparation	**In progress**	07	Incident Response Policy drafted (Part 7); plan and exercise to follow
A.5.31	Legal, statutory, regulatory and contractual requirements	**Planned**	03	Obligations register per country with named owners
A.5.34	Privacy and protection of PII	**Planned**	05	Customer-data controls incl. cross-border transfers and NDPC duties

20 controls: 7 organizational, 3 people, 3 physical, 7 technological. Names and numbers follow ISO/IEC 27001:2022 Annex A.

Document NP-ISMS-DOC-003 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 cl. 6.1.3(d); ISO 27002:2022

UPDATED DOCUMENT

Clauses 6 and 7: people and physical controls (6 of 20)

Annex A	Control name	Status	Risk	Justification
A.6.1	Screening	**To be verified**	09	Checks for staff and agents with data access; verify consistency across countries
A.6.3	Information security awareness, education and training	**Planned**	04	One annual training baseline for staff and agents in every region
A.6.7	Remote working	**Planned**	09	Secure remote-access and device rules
A.7.1	Physical security perimeters	**To be verified**	10	Protected areas in headquarters and country offices
A.7.2	Physical entry	**To be verified**	10	Entry control and visitor management in each office
A.7.14	Secure disposal or re-use of equipment	**To be verified**	10	Secure wiping of media before disposal or re-use, with records

UPDATED DOCUMENT

Clause 8 technological controls (7 of 20)

Annex A	Control name	Status	Risk	Justification
A.8.3	Information access restriction	**Planned**	01	Limit third-party and staff access to what each role or integration needs
A.8.5	Secure authentication	**Planned**	01	Strong authentication incl. MFA for staff, admins and API partners
A.8.15	Logging	**Planned**	06	Central logs of access, API calls and transactions, protected retention
A.8.16	Monitoring activities	**Planned**	06	Monitoring for fraud and anomalous activity, incl. cross-border and API use
A.8.20	Networks security	**To be verified**	08	Segmentation and protection of networks carrying payment data
A.8.24	Use of cryptography	**To be verified**	05, 08	Encryption of data at rest and in transit; key management
A.8.26	Application security requirements	**Planned**	01	Security requirements for the mobile app and merchant API platform

All 20 applicable. No control is marked Implemented until evidence is reviewed; other Annex A controls are to be assessed before the SoA is finalized for certification.

Prepared by: GRC Analyst / Consultant	Approval: Chief Executive Officer	Approval: Chief Information Security Officer
Oluwatosin A. Fagbayimu Sign: Date: 22.10.26	Name: _____ Sign: _____ Date: _____	Name: _____ Sign: _____ Date: _____

Document NP-ISMS-DOC-003 | v1.0 | Status: issued for review | Owner: CISO | Approver: CEO | Date: 22 Oct 2026 | Next review: 22 Oct 2027 | ISO 27001 cl. 6.1.3(d); ISO 27002:2022

Partners will ask six questions; most answers are not ready

Question a partner will ask	Evidence to hand over	Source	Status today
Who is accountable for security and compliance in each country?	Named owners; responsibility matrix	Part 3	**Drafted; appointments pending**
How are partners approved before they get access?	Onboarding standard, supplier register, completed assessments	Part 6	**Requirement set; no assessments yet**
What can each integration access, and who approved it?	Integration inventory with scopes and owners	Part 5	**Missing**
How do you identify and rate risk?	Procedure, register, workshop records	Parts 4–5	**Method drafted; workshops pending**
Which laws apply in each country, and how do you comply?	Obligations register with evidence	A.5.31	**Missing**
What happens when an incident occurs, and who is told?	Incident Response Policy, plan, exercise report	Part 7	**Policy drafted; no exercise yet**

Audit conclusion: ISMS readiness by ISO 27001 clause

Clause	What the audit found	Readiness
4 Context	Scope, context and interested parties drafted (Part 2); exclusions to be confirmed	**Drafted**
5 Leadership	Commitment statement, objectives and roles drafted (Part 3); awaiting CEO approval	**Drafted**
6 Planning	Risk method and initial register of ten risks; treatment plan and SoA drafted (Parts 4, 5, 8); policies drafted (Parts 6, 7)	**Drafted**
7 Support	Training, competence and document control not yet evidenced	**Gap**
8 Operation	No operating evidence yet; risk treatment and supplier controls still to roll out	**Gap**
9 Performance evaluation	Internal audit and management review planned for months 4–12	**Not started**
10 Improvement	Corrective-action process and register not yet in place	**Not started**

Conclusion: not yet ready for certification. Clauses 4–6 are drafted; evidence for clauses 7–10 is the work of the next 12 months.

Glossary and references

Term	Meaning
API	Interface for merchants and partners
CBN	Central Bank of Nigeria
GRC	Governance, risk and compliance
ISMS	Information security management system
NDPC / NDPA	Nigeria Data Protection Commission / Act 2023
PII	Personally identifiable information
RMC	Risk management and compliance team
SoA	Statement of Applicability

[1] NovaPay GRC Audit case study and Head of Operations request (course material).

[2] GRC Project Submission Checklist, April 2026.

[3] ISO/IEC 27001:2022 and [4] ISO/IEC 27002:2022 (supplied copies).

[5] ISO 31000:2018, Risk management – Guidelines.

[6] NIST (2024). Cybersecurity Framework 2.0. nist.gov/cyberframework

[7] PCI SSC. PCI DSS v4.0.1 and future-dated requirements after 31 March 2025.

[8] NDPC. NDPA 2023 GAID 2025. ndpc.gov.ng

[9] Regulation (EU) 2016/679 (GDPR), Article 3.

[10] Central Bank of Nigeria, payments system pages. cbn.gov.ng

Web sources checked 22 October 2026. Legal applicability is subject to review by NovaPay Legal.